



Government
Digital Service



Department for
Science, Innovation
& Technology

Human security in projects: A Secure By Design guide

Contents

Contents	2
Background	3
Vetting	3
User training	3
Usability as a security feature	4
Test early	4
Make reporting easy	4
Authorisation, insider threats and toxic combinations	4
Understand insider risk	4
Avoid toxic combinations by separating duties	5
Consider behaviour analytics	5
Acceptable use policies (AUPs)	5
Have a clear policy that sets expectations	5
Recognise that AUP rules have mixed drivers	6
Include AUP awareness in onboarding	6
Automation	6
More information	6

Background

Secure By Design is the UK Government's framework for improving the security of digital project delivery. Much historic guidance has focused on technical security such as encryption, patches and networking, but the human elements of security are vitally important, too.

Vetting

The [Baseline Personnel Security Standard](#) (BPSS) is the recognised check for people working with government data and systems.

Although it is not an explicit requirement of Secure By Design, some projects which touch on high-impact systems will require additional security vetting for people who have access to SECRET or TOP SECRET assets. The process is managed by [United Kingdom Security Vetting \(UKSV\)](#), but be aware that lead-times are very long, and there can be challenges in recruitment of new people, so you should anticipate any changes in personnel needs far in advance; ideally within the first Secure By Design activities, especially [Considering security within the business case](#) and [Identifying security resources](#).

As with many other aspects of security, your vetting decisions should be informed by the nature of the project and your organisation's risk appetite.

User training

End-user security training is usually an ongoing requirement, more 'operational' than 'project'. However, you should also consider:

- changes to training when new systems are deployed
- changes to training when existing systems gain new capabilities
- training within the context of your project delivery

For example, if you are delivering a service which enables new ways of using and sharing personal data, your colleagues may need more [data protection training](#).

Carrying out the Secure by Design activities [Identifying security resources](#) and [Agreeing roles and responsibilities](#) at the start of a project could help you identify skills gaps. This may highlight a need for new training. Recent findings show a shortage of cyber security skills across government, so identifying these gaps is particularly important. Addressing them will improve the delivery of secure solutions.

Usability as a security feature

Poor usability encourages users to develop their own shortcuts and workarounds which may undermine the effectiveness of your system's controls. These problems are rarely found by pentests and there may be a temptation to ignore them as 'not our problem'. However, in a holistic view of security, if your system encourages its users to act less securely, it's a problem you should address.

A famous example of poor usability leading to workarounds is passwords. A strict login password requirement seems 'more secure', but in practice this can encourage users to reuse passwords across different systems, or even write them down on post-it notes. Be wary of older guidance, which used to recommend very difficult passwords - much of it has been updated, such as [NIST 800-63](#).

Test early

Early testing with users can help identify potential friction earlier in the project, making solutions easier to implement and reducing rework.

If your project is PRINCE2, this should align neatly with the user-focused tasks in Quality Management; reducing user-side workarounds can be considered part of quality control.

If you are using the UK Government's preferred agile framework, capture the preferred user interaction with [user stories](#).

Make reporting easy

Your services should make it easy for users to report incidents, breaches or suspicious behaviour. Behind the scenes, there should be a way to investigate these reports promptly.

Authorisation, insider threats and toxic combinations

Understand insider risk

Your threat modelling activity should identify possible situations where an insider has both the capability and the motive to abuse the system you are implementing.

For example, in a travel booking system, an insider might be able to create and approve expense claims. Your processes should prevent any single person doing this unobserved.

Organisations typically [manage insider risk](#) through:

- approvals

- reviews
- countersignatures
- logging

However, these controls can fail if insiders are able to sidestep or subvert these mechanisms. An example might be a sysadmin who could create a new account or delete a log. This is the challenge of toxic combinations - when someone covered by the controls can also circumvent them.

Avoid toxic combinations by separating duties

It is important for your solution to avoid toxic combinations where the roles who are covered by controls also have a technical ability to sidestep those controls. 'Separation of duties' has long been an established concept in fraud prevention, but the National Cyber Security Centre (NCSC) has some helpful cyber security guidance [on limiting the impact of compromise](#).

In typical new projects, your solution will also rely on a separate system for identity, such as federated authentication. You should check:

- whether the roles within your new service overlap with the roles that can create or modify accounts in your identity and access management (IDAM) system
- ways to mitigate or eliminate this risk

NCSC offers a useful [introduction to IDAM](#).

Consider behaviour analytics

Some cloud services allow you to implement behaviour analytics. With some degree of automation, this can:

- identify problematic patterns of behaviour
- drive risk-based responses to particular devices or sessions

NCSC has more information about [assessing behaviour](#).

Acceptable use policies (AUPs)

Have a clear policy that sets expectations

Your organisation should have an acceptable use policy (AUP), perhaps as part of a broader IT policy. This should set out expectations for how people use the IT systems that you provide.

As this policy is explicitly required under [ISO 27001](#), there are various online resources and templates available, even if your organisation is not formally aiming for ISO 27001 compliance.

Recognise that AUP rules have mixed drivers

Some requirements of an AUP may be explicitly security-driven, for example:

- locking screens
- disallowing third-party filesharing

But when cyber security is only one of several drivers, they are often hybrid. For example, a rule against social media use might reduce the risk of data leakage, but could also be based on concerns about reputational damage, productivity or tensions with colleagues.

Include AUP awareness in onboarding

New starters should be made aware of the acceptable use policy as part of onboarding.

Automation

Automating data processing which was previously manual can reduce the day-to-day risk of manual errors such as typos and some kinds of delay. This supports data integrity.

However automation can actually introduce a new key-person risk, especially when it uses End-User Computing (EUC) tools like complex scripts and spreadsheet formulas. If only one or two people know how to maintain the automation, your [risk register](#) should consider what happens if these people are not available when the automation breaks or needs to be updated.

More information

- [Secure by Design principles \(UK Government Security\)](#)
- [Secure by Design activities \(UK Government Security\)](#)